

Manual 31 — NYDFS 23 NYCRR Part 500 Controlled Implementation

****Language:**** English

****Regulatory baseline:**** 23 NYCRR Part 500 as amended by the Second Amendment effective November 1, 2023, release-time verified 2026-08-31.

****Controlled boundary:**** This manual is implementation guidance. It does not provide legal advice, determine Covered Entity or Class A status, establish an exemption, make a regulatory filing, or certify compliance. Binding regulation, DFS explanatory material, organization practice, and evidence are kept distinct.

Chapter 01 — Purpose, scope, and controlled-source hierarchy

Use Part 500 and current DFS final-adoption materials as the binding-source layer. Treat DFS FAQs, training, checklists, implementation timelines, resource-center explanations, and industry letters as dated explanatory or advisory material; organization procedures must never be presented as the regulation itself.

Chapter 02 — Applicability and Covered Entity analysis

Maintain a documented applicability assessment identifying the license, registration, charter, certificate, permit, accreditation, or similar DFS authorization that may bring an entity within Part 500. Escalate ambiguous entity, affiliate, branch, and regulated-activity questions for qualified legal/regulatory analysis rather than inferring status from a generic business description.

Chapter 03 — Definitions and terminology governance

Maintain a controlled glossary for Part 500 concepts such as Covered Entity, Cybersecurity Event, Information System, Nonpublic Information, Senior Governing Body, CISO, Class A Company, and Third Party Service Provider. Preserve regulatory meaning when internal terminology differs and record any interpretation used in implementation decisions.

Chapter 04 — Exemptions and limited-exemption controls

Document the specific regulatory basis, facts, approval, filing status, effective period, continuing obligations, and change triggers for any exemption or limited exemption. An exemption record must not be treated as permanent when size, revenue, operations, affiliation, or other relevant facts change.

Chapter 05 — Class A Company determination and obligations

Maintain a dated Class A determination based on the current regulatory definition and applicable facts. Where Class A obligations apply, identify enhanced requirements such as additional independent audits, privileged-access controls, password/security controls, endpoint detection and response, centralized logging/security-event alerting, and other

enhanced measures without extending them to entities for which the regulation does not require them.

Chapter 06 — Cybersecurity governance and senior accountability

Define the Senior Governing Body's oversight responsibilities, management reporting, escalation, resource decisions, risk acceptance, and evidence of review. Governance evidence should demonstrate informed oversight rather than merely showing that cybersecurity appeared on an agenda.

Chapter 07 — CISO role, authority, reporting, and evidence

Document the CISO's authority, independence or reporting relationship, responsibilities, resources, use of affiliates or third parties where permitted, and required reporting to the Senior Governing Body. Preserve reports, findings, material issues, remediation decisions, and acknowledgments as governance evidence.

Chapter 08 — Cybersecurity program design and maintenance

Operate a risk-based cybersecurity program designed to protect information systems and Nonpublic Information and to support detection, response, recovery, and regulatory duties. Map program components to owners, policies, procedures, technology, evidence, testing, and improvement actions.

Chapter 09 — Cybersecurity policy framework

Maintain approved written cybersecurity policies covering the regulatory topics applicable to the Covered Entity. Each policy should identify owner, scope, approval authority, review cadence, related procedures, evidence, exceptions, and change triggers; policy existence alone does not demonstrate operating effectiveness.

Chapter 10 — Cybersecurity risk assessment methodology

Perform and maintain the risk assessment required by Part 500 using defined criteria, relevant threats, vulnerabilities, business operations, information systems, Nonpublic Information, controls, and material changes. Retain methodology, inputs, assumptions, approvals, identified risks, treatment decisions, and evidence that the assessment informs the cybersecurity program.

Chapter 11 — Asset inventory and technology lifecycle controls

Maintain the information-system asset inventory required by the amended regulation with the attributes, ownership, update process, and retention necessary to support risk management and security operations. Reconcile inventory coverage against cloud, endpoint, server, application, network, data, AI, and other relevant technology sources and document gaps.

Chapter 12 — Access privileges and least-privilege governance

Limit user access privileges to systems and Nonpublic Information based on job responsibilities and legitimate business need. Define provisioning, approval, periodic review, transfer, termination, emergency access, exception handling, and evidence sufficient to show that access remains appropriate over time.

Chapter 13 — Privileged access management

Apply enhanced governance to privileged accounts, service accounts, administrative tools, and high-impact access. Record accountable owner, business need, authentication, monitoring, review, vaulting or equivalent safeguards, emergency-use controls, and prompt removal when privileges are no longer required.

Chapter 14 — Multi-factor authentication requirements and exceptions

Implement MFA consistent with the amended Part 500 requirements and the Covered Entity's applicable facts. Any permitted alternative or exception must have documented regulatory basis, CISO approval where required, risk analysis, compensating protection, scope, duration, monitoring, and revalidation trigger.

Chapter 15 — Vulnerability management and penetration testing

Operate vulnerability scanning/assessment, remediation, penetration testing, and risk-based follow-up at the frequencies and scope required by Part 500. Preserve scope, methodology, findings, severity rationale, remediation, retesting, exceptions, and evidence that material weaknesses are tracked to closure.

Chapter 16 — Secure development and application-security controls

Maintain written secure-development and application-security procedures for internally and externally developed applications as applicable. Define secure design, code/change review, dependency risk, testing, vulnerability remediation, release approval, and periodic review based on the risk assessment.

Chapter 17 — Encryption and compensating-control decision records

Protect Nonpublic Information in transit and at rest using encryption meeting applicable Part 500 expectations. Where the regulation permits an alternative because encryption is infeasible or another controlled exception applies, document the decision, CISO approval, compensating controls, risk, duration, monitoring, and periodic reconsideration.

Chapter 18 — Monitoring, logging, and detection controls

Implement risk-based monitoring of authorized-user activity and controls designed to detect unauthorized access, use, or tampering. Maintain logging, security-event alerting, review

responsibilities, retention, tuning, escalation, and investigation records proportional to regulatory requirements and the Covered Entity's risk assessment.

Chapter 19 — Endpoint, network, and infrastructure safeguards

Use risk-based safeguards against malicious code and unauthorized activity across endpoints, networks, email, web traffic, remote access, infrastructure, and administrative channels. Class A-specific tooling requirements must remain distinguishable from baseline Covered Entity obligations.

Chapter 20 — Third-party service-provider cybersecurity risk management

Maintain a Third Party Service Provider security program/policy that addresses risk assessment, due diligence, minimum security practices, contractual protections, access, incident notification, monitoring, termination, and evidence. The Covered Entity retains responsibility for its Part 500 duties even when operational activities are outsourced.

Chapter 21 — Cybersecurity awareness and training

Provide periodic, at least annual, cybersecurity awareness training consistent with Part 500 and update it based on identified risks. Include social-engineering content and retain population, completion, exceptions, curriculum/version, timing, and follow-up evidence rather than relying solely on attendance counts.

Chapter 22 — Incident-response planning and execution

Maintain an incident-response plan addressing preparation, roles, escalation, investigation, containment, eradication, recovery, communications, evidence, regulatory analysis, lessons learned, and plan updates. Exercises and actual events should produce actionable findings and tracked remediation.

Chapter 23 — Business continuity and disaster recovery

Maintain business continuity and disaster recovery plans aligned with the amended Part 500 requirements and cybersecurity scenarios. Define critical operations, recovery objectives, backups, restoration testing, dependencies, communications, alternate arrangements, annual or applicable testing, findings, and improvement actions.

Chapter 24 — Cybersecurity Event determination and escalation

Use a documented decision process to determine whether an occurrence meets the regulation's Cybersecurity Event definition and whether additional regulatory thresholds are implicated. Preserve facts, time of awareness, analysis, decision owner, legal/regulatory consultation where needed, and escalation history.

Chapter 25 — Notice to the Superintendent and reporting decision records

Maintain a time-sensitive decision and filing process for events reportable to DFS. Record trigger analysis, relevant regulatory criteria, awareness timestamps, decision authority, information submitted, supplemental communications, portal confirmation, and retained evidence; do not substitute internal severity labels for the regulatory reporting test.

Chapter 26 — Extortion-payment notification and evidence boundaries

Maintain a controlled process for any extortion payment that could trigger Part 500 notification or supporting-information requirements. Preserve authorization, timing, payment facts, legal/sanctions review where applicable, reporting analysis, notification evidence, and required follow-up information without treating payment approval as proof of regulatory compliance.

Chapter 27 — Annual compliance certification / acknowledgment governance

Operate an annual filing process that distinguishes certification of material compliance from acknowledgment of noncompliance where applicable under current Part 500. Maintain responsible signatories, supporting evidence, known gaps, remediation status, decision rationale, filing confirmation, and records needed to support the representation made to DFS.

Chapter 28 — Senior Governing Body oversight and evidence retention

Provide the Senior Governing Body with information sufficient to exercise required cybersecurity oversight, including material risks, incidents, control gaps, CISO reporting, remediation, exceptions, resources, and significant changes. Retain minutes, materials, approvals, and follow-up evidence without overstating them as independent assurance.

Chapter 29 — Remediation, exception, and risk-acceptance governance

Track regulatory/control deficiencies through documented owners, severity, root cause, corrective actions, due dates, interim safeguards, validation, and closure. Exceptions and risk acceptance must not silently waive a Part 500 obligation; any legally permissible alternative must be supported by the regulation, appropriate approval, and evidence.

Chapter 30 — Testing, metrics, assurance, and continuous improvement

Define testing and metrics that demonstrate program operation, identify degradation, and support management decisions. Preserve scope, population, methodology, results, limitations, trend definitions, follow-up, and independence where required; dashboard percentages alone are not proof of compliance.

Chapter 31 — Evidence architecture, auditability, and records retention

Maintain traceable evidence linking regulatory topic, policy, procedure, owner, system, execution period, test, exception, finding, remediation, approval, and source version. Apply retention and access controls appropriate to Part 500, other applicable law, litigation/regulatory needs, and organizational policy, while protecting sensitive security information.

Chapter 32 — Release-time regulatory change control and implementation roadmap

Revalidate Part 500 and the DFS Cybersecurity Resource Center before each controlled release. Assess amendments, FAQs, implementation guidance, enforcement developments, advisories, filing changes, and relevant deadlines for impact, then update mappings, procedures, evidence requirements, training, and implementation plans through controlled change governance.

Minimum implementation evidence set

Maintain, as applicable: source/version record; applicability assessment; exemption and Class A determinations; CISO mandate/report; program charter; policy register; risk assessment; asset inventory; access and privileged-access reviews; MFA decision records; vulnerability and penetration-test evidence; application-security evidence; encryption decisions; monitoring/log records; third-party risk records; training evidence; incident and BCDR records; DFS reporting analyses and filing confirmations; annual certification/acknowledgment evidence; Senior Governing Body oversight records; remediation/exception records; metrics/testing pack; and release-time source verification.